LEMBAR PERSIAPAN & PANDUAN BIMBINGAN TUGAS AKHIR

# Keunggulan Sistem SOAR vs. Windows Defender Standalone

Studi Kasus: Deteksi & Respons Ancaman Malware dan Phishing di CV Bali Handmade

**Mahasiswa:** Ravi Arnan Irianto (NIM: 2305551076) **Dosen Pembimbing:** I Nyoman Piarsa

## 1 Elevator Pitch (Analogi 30 Detik untuk Dosen)

> "Pak, **Windows Defender** itu seperti **satpam lokal yang berdiri di dalam masing-masing kamar**. Kalau satpam melihat ada orang mencurigakan, dia tangani sendiri di kamar itu, tetapi manajer gedung di kantor pusat tidak pernah diberi tahu secara real-time.
>
> Sedangkan **Sistem SOAR** yang saya bangun adalah **Pusat Komando (SOC) terpadu**. Sistem ini menghubungkan seluruh satpam di 50-100 PC, memeriksa catatan pelaku ke puluhan intelijen global (VirusTotal, MalwareBazaar, MISP), langsung memutus jalur pelariannya di jaringan (sinkhole domain phishing), dan mengirim notifikasi ringkas ke Telegram admin agar admin bisa mengambil keputusan dalam 1 klik dari HP."

## 2 Masalah Riil di Lapangan (CV Bali Handmade)

Di lingkungan kerja CV Bali Handmade (toko, kasir, gudang, staf administrasi), mengandalkan Windows Defender lokal terbukti memiliki celah keamanan serius:

### Silo / Tanpa Visibilitas Admin

Karyawan sering mengabaikan pop-up Defender atau mematikan proteksi demi membuka file invoice/desain dari supplier. Admin IT tidak pernah tahu komputernya sedang terinfeksi.

### Ancaman Phishing & Rekayasa Sosial

Staf sering menerima link penipuan via WhatsApp Web atau email. Defender lokal tidak memblokir domain berbahaya tersebut untuk seluruh jaringan kantor.

### Risiko False Positive pada Dokumen Kerja

Antivirus yang serba otomatis sering menghapus macro Excel keuangan atau file nota toko yang sah, menghentikan operasional bisnis dan membingungkan staf non-teknis.

### Keterbatasan Perangkat Kasir & Toko

PC toko berspesifikasi rendah sering mengalami lemot akibat proses scanning antivirus berat (MsMpEng), sedangkan server toko berjalan di Linux (tanpa Defender).

## 3 Lima Pilar Keunggulan Sistem SOAR Ini

### 1. Visibilitas & Orkestrasi Terpusat

Seluruh event FIM (Downloads, Desktop, USB) dilaporkan real-time ke n8n dan database audit trail. Admin mengontrol puluhan workstation dari satu dashboard web & Telegram.

### 2. Konsensus Global Multi-Vendor

Tidak bergantung pada 1 vendor (Microsoft). Hash berkas diuji ke **VirusTotal (70+ engine AV)**, MalwareBazaar, dan feed MISP OSINT. Akurasi keputusan jauh lebih tinggi.

### 3. Human-in-the-Loop (HITL) Fleksibel

Jika skor ancaman tinggi (≥20): isolasi otomatis seketika. Jika ambigu (skor 1-19): bot Telegram mengirim ringkasan AI dan tombol **[Isolasi]** / **[Abaikan]**. Operasional kantor tetap aman dari salah hapus.

### 4. Pertahanan Vektor Ganda (Malware + Phishing)

Menangani berkas malware sekaligus link phishing. Deteksi URL jahat langsung memicu **domain sinkhole** (0.0.0.0 di hosts/DNS) sehingga seluruh kantor terlindungi dalam ~2 detik.

### 5. Agen Ultra-Ringan (Rust) & Bebas Biaya Lisensi (Rp 0)

Agen endpoint mandiri (`agent-rs`) hanya memakan **~7-10 MB RAM** (menghemat >90% memori dibanding AV konvensional) dan file executable hanya ~5,4 MB. Seluruh stack berbasis open-source (Wazuh, n8n, Rust), menggantikan kebutuhan solusi komersial mahal seperti Microsoft Sentinel (lisensi E5) yang tidak terjangkau bagi UKM.

## 4 Tabel Komparasi Head-to-Head

| Parameter Evaluasi | Windows Defender Standalone | Sistem SOAR Proyek Ini |
|---|---|---|
| **Kategori Sistem** | Endpoint Antivirus lokal (berjalan di masing-masing PC) | **SOAR (Orkestrasi terpusat multi-komponen)** |
| **Cakupan Sistem Operasi** | Khusus ekosistem Windows | **Lintas-OS: Windows, Linux Server, macOS** |
| **Basis Penilaian Bahaya** | Single-vendor (database & cloud Microsoft) | **Multi-vendor (VirusTotal 70+ AV, MalwareBazaar, MISP)** |
| **Visibilitas Admin IT** | Nol (hanya pop-up di layar pengguna lokal) | **Real-time di Telegram Bot & Web Dashboard** |
| **Penanganan Kasus Ragu** | Hapus otomatis atau diabaikan user | **Human-in-the-Loop: Tombol persetujuan analis di Telegram** |
| **Mitigasi Serangan Phishing** | Terbatas proteksi browser Edge (SmartScreen) | **Domain sinkhole aktif lintas perangkat (~2,13 detik)** |
| **Konsumsi Memori (RAM)** | ~150 - 300+ MB (MsMpEng.exe) | **~7 - 10 MB (Agen Rust mandiri)** |
| **Biaya Lisensi Organisasi** | Mahal untuk fitur terpusat (Lisensi M365 E5) | **100% Open-Source (Biaya lisensi Rp 0)** |

## 5 Bukti Kuantitatif Hasil Uji Coba Nyata (Data Empiris)

Klaim keunggulan sistem ini dibuktikan lewat data pengujian terukur pada lingkungan live:

| 0,04 dtk | 1,68 dtk | 2,13 dtk | 100% |
|---|---|---|---|
| MTTR Karantina Malware (Agen Rust, cache) | MTTR Karantina Malware (Stack Wazuh) | MTTR Auto-Block Phishing (Domain Sinkhole) | FP Suppression (Noise Berkas Jinak Ditekan) |

## 6 Antisipasi Pertanyaan Kritis Dosen & Rekomendasi Jawaban

**Q1: "Kalau Defender sudah otomatis hapus malware di laptop, untuk apa agen kita kirim alert lagi?"**

**Jawaban:** "Pertama, Defender di laptop tidak melaporkan insiden ke admin kantor. Karyawan sering kali tidak sadar komputernya menjadi pintu masuk peretasan.
Kedua, malware modern sering menyamar sebagai file script, dokumen makro, atau varian baru yang belum ada signature-nya di database Microsoft. Sistem SOAR mendeteksi berkas seketika saat masuk (FIM), lalu menguji reputasinya ke 70+ vendor global.
Sistem ini tidak menggantikan Defender, melainkan menjadi lapisan intelijen dan orkestrasi di atasnya (konsep *defense-in-depth*)."

**Q2: "Microsoft kan sudah punya Microsoft Sentinel untuk orkestrasi SOAR, kenapa harus buat sendiri?"**

**Jawaban:** "Microsoft Sentinel membutuhkan lisensi korporat tier atas (Microsoft 365 E5) seharga puluhan dolar per user per bulan, ditambah biaya konsumsi data log per gigabyte di Azure cloud. Untuk UKM seperti CV Bali Handmade dengan 50-100 workstation, biaya tersebut tidak realistis.
Tugas akhir ini membuktikan bahwa kapabilitas SOAR modern dengan waktu respons sub-detik dapat dibangun sepenuhnya di atas infrastruktur open-source berbiaya lisensi nol."

**Q3: "Bagaimana kalau koneksi internet mati atau kena kuota rate limit VirusTotal?"**

**Jawaban:** "Sistem menerapkan tiga lapis perlindungan: (1) *Local verdict cache* berbasis hash SHA-256 di server, sehingga hash yang sudah pernah diperiksa tidak query ulang ke internet; (2) Fallback otomatis ke MalwareBazaar dan AlienVault OTX jika VirusTotal rate-limit; (3) Status bertanda *unverified* yang langsung dieskalasi sebagai notifikasi Telegram ke analis, memastikan file mencurigakan tidak lolos begitu saja."

**Q4: "Mengapa memilih n8n sebagai mesin orkestrasi dan Rust untuk agen?"**

**Jawaban:** "n8n adalah mesin workflow visual modern yang memungkinkan playbook respons dimodifikasi dengan sangat cepat tanpa coding ulang daemon dari nol. Sedangkan agen ditulis dalam Rust untuk menghasilkan binary statis tunggal tanpa runtime, dengan footprint RAM hanya ~7-10 MB, sehingga sama sekali tidak membebani performa PC kasir maupun laptop kerja karyawan."